

CEH v13 Practice Questions – Module 9: Social Engineering

1. What is social engineering in the context of cybersecurity?

- A. Using software to exploit a network
- B. Exploiting human behavior to gain unauthorized access
- C. Reverse engineering an application
- D. Cracking password hashes

Answer: B

2. Which of the following is an example of a social engineering attack?

- A. SQL injection
- B. Sending a phishing email to steal credentials
- C. Performing a port scan
- D. Exploiting a buffer overflow vulnerability

Answer: B

3. Which social engineering technique involves pretending to be someone in authority?

- A. Phishing
- B. Tailgating
- C. Pretexting
- D. Shoulder surfing

Answer: C

4. What is tailgating in a physical security context?

- A. Watching someone type their password
- B. Following someone into a restricted area without authentication
- C. Using a fake ID to access a server room
- D. Bypassing biometric authentication

Answer: B

5. What does phishing typically involve?

- A. Physically accessing a secure server
- B. Sending fraudulent emails to trick users
- C. Stealing a mobile phone to gain access
- D. Using malware to exploit zero-day vulnerabilities

Answer: B

6. Which of the following is a type of phishing that targets specific individuals?

- A. Spear phishing
- B. Whaling
- C. Vishing
- D. Clone phishing

Answer: A

7. What is vishing?

- A. A phishing attempt via voicemail
- B. A phishing attack via voice calls
- C. A phishing email that spoofs government emails
- D. A visual-based shoulder surfing technique

Answer: B

8. Which technique involves observing someone's screen or keyboard to obtain information?

- A. Pretexting
- B. Shoulder surfing
- C. Tailgating
- D. Vishing

Answer: B

9. Which type of social engineering uses a copy of a legitimate message to trick users?

- A. Spear phishing
- B. Whaling
- C. Clone phishing
- D. Dumpster diving

Answer: C

10. What is the term for targeting high-profile individuals with social engineering?

- A. Vishing
- B. Whaling
- C. Tailgating
- D. Baiting

Answer: B

11. Which of the following is a countermeasure for social engineering?

- A. Firewalls
- B. Regular user training and awareness programs
- C. Port scanning
- D. Antivirus software

Answer: B

12. What does a baiting attack rely on?

- A. Threatening to reveal sensitive data
- B. Offering something enticing to lure a victim
- C. Monitoring open network ports
- D. Injecting malicious scripts into websites

Answer: B

13. Which type of social engineering attack occurs in person and not over a network?

- A. Phishing
- B. Vishing
- C. Pretexting
- D. Tailgating

Answer: D

14. Which of the following is most effective in preventing social engineering attacks?

- A. IP whitelisting
- B. User awareness training

- C. Email encryption
- D. Patch management

Answer: B

15. How can an attacker use social engineering in a helpdesk scenario?

- A. Scan for open ports on the server
- B. Trick the helpdesk into resetting a password
- C. Create a fake website to collect passwords
- D. Install keyloggers remotely

Answer: B

16. What is a good practice to detect phishing emails?

- A. Trust all attachments from known users
- B. Click links to verify authenticity
- C. Check the sender's domain and hover over links
- D. Respond immediately if it seems urgent

Answer: C

17. What is the main difference between spear phishing and regular phishing?

- A. Spear phishing is always sent via SMS
- B. Phishing targets organizations; spear phishing targets random people
- C. Spear phishing is more targeted and personalized
- D. There is no difference

Answer: C

18. Which scenario best describes a pretexting attack?

- A. Sending mass emails to get bank credentials
- B. Following someone into a secure building
- C. Pretending to be a tech support agent to get a password
- D. Digging through trash to find sensitive information

Answer: C

19. Dumpster diving is best described as:

- A. Exploiting system vulnerabilities
- B. Searching trash for sensitive information
- C. Manipulating DNS records
- D. Sniffing packets on a network

Answer: B

20. What is the primary human vulnerability exploited in social engineering?

- A. Trust
- B. Ignorance
- C. Curiosity
- D. All of the above

Answer: D

21. Which tool can simulate phishing attacks to test employee awareness?

- A. Metasploit
- B. GoPhish
- C. Nmap
- D. Nessus

Answer: B

22. How does USB baiting work?

- A. Encrypts USB drives using ransomware
- B. Uses USB drives to transfer large malware payloads
- C. Leaves infected USBs in public places for users to plug in
- D. Blocks USB ports with malware

Answer: C

23. Which of the following is a sign of a phishing website?

- A. HTTPS and valid certificate
- B. Domain spelling errors and suspicious login forms
- C. Clean layout with official logos
- D. Linked from a government website

Answer: B

24. Which regulation often includes provisions for user security awareness training?

- A. PCI-DSS
- B. DMARC
- C. DNSSEC
- D. SPF

Answer: A